ZAPATA TECHNOLOGY · NOVEMBER 2026

github.com/Zapata-Technology/bigbang-chainguard

Big Bang on Chainguard

Run the same, unmodified Big Bang on images with a fraction of the vulnerabilities, and turn FIPS on with one switch.

96% fewer High CVEs than Iron Bank's base images alone*

44 Big Bang packages mapped, standard and FIPS

38 Kubernetes tests, each proving the app works

*67 images: the complete Chainguard replacement, application included, against the Iron Bank image's base alone. grype scan, 2026-11-02.

Same Big Bang, a fraction of the vulnerabilities

1

The problem

Iron Bank images sit on bases that alone carry 7,528 High and Medium CVEs across 67 images. Every finding is triage, paperwork and ATO delay.

2

The fix

Chainguard rebuilds each image from source, with a published SLA: KEV-listed CVEs fixed in 1 day, Criticals in 7. This project runs unmodified Big Bang on those images, FIPS included.

3

The proof

96% fewer High CVEs than Iron Bank's bases alone. 38 Kubernetes tests. Big Bang's default packages healthy on CIS-hardened RKE2.

The ask: a Chainguard Enterprise plan sized to your packages (FIPS included), and a 60-day pilot on a development cluster.

Every CVE in a base image is work for your team

7,528

High and Medium CVEs in the base images alone, before any application is added

- 840 High and 6,688 Medium, summed over 67 Iron Bank images
- Most are built on Red Hat UBI 9; this counts that base layer only

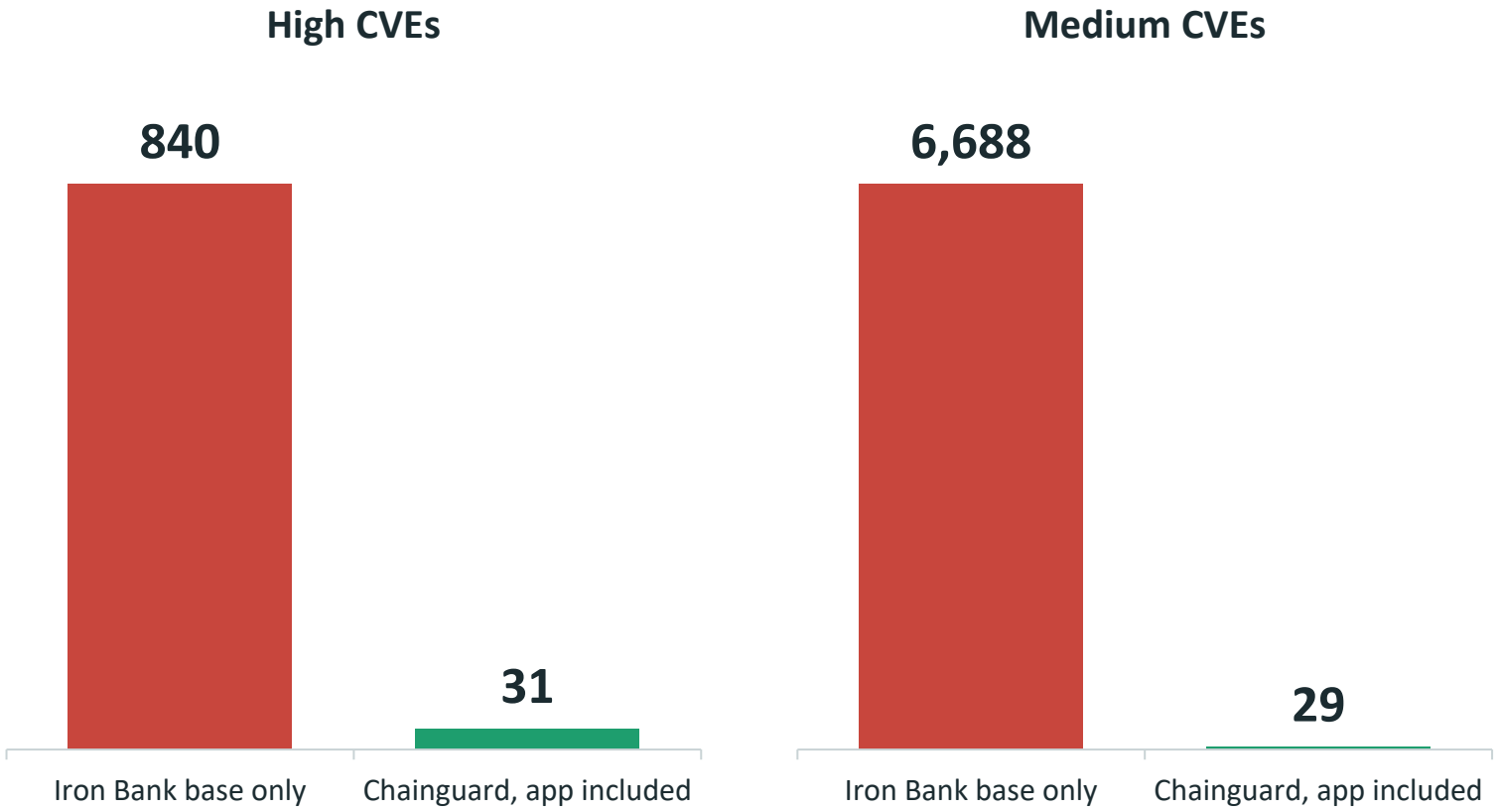
What each finding costs

1. **Triage** Is it reachable, exploitable, fixed upstream?
2. **Document** A justification or POA&M entry in the ATO package
3. **Track** Chase the fix, re-scan, update the record
4. **Repeat** New CVEs are published against the same base packages every week

CVE counts: grype, 2026-11-02, public copies of the base images each Iron Bank recipe names (Iron Bank's own images need an account to scan). Counts summed per image.

Chainguard images carry 96% fewer High CVEs

Complete Chainguard images vs. Iron Bank's base images alone, same 67 images



96%
fewer High CVEs

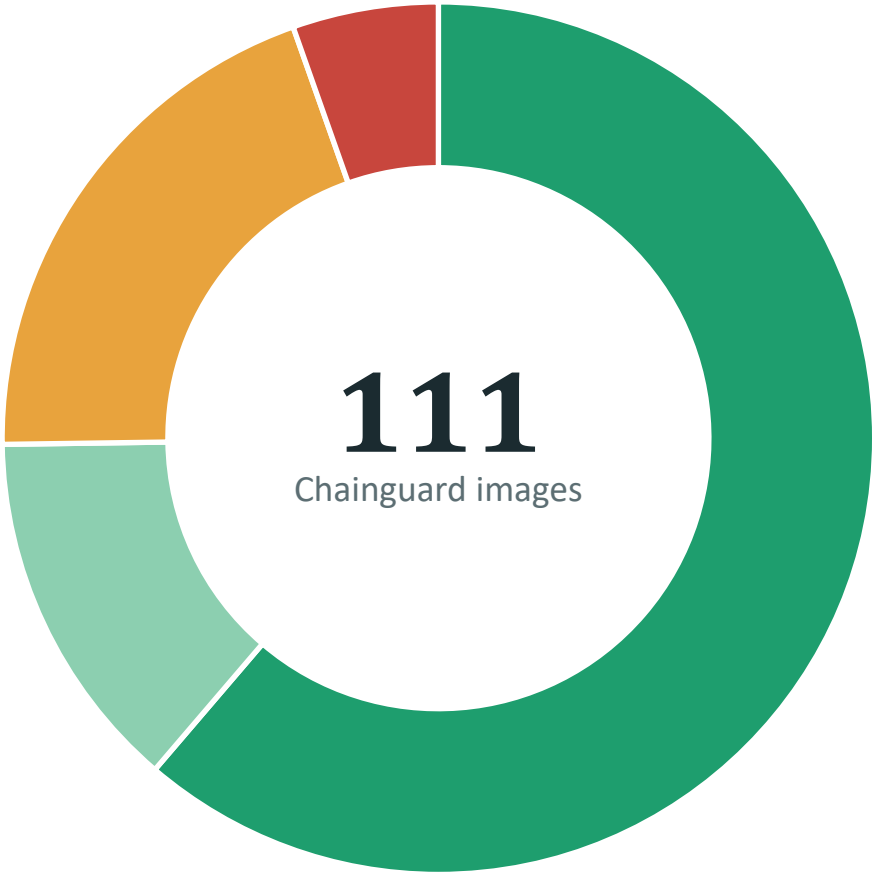
99.6%
fewer Medium CVEs

53 of 67
Chainguard images beat the Iron Bank base alone on Critical + High

83 MB
median Chainguard image, app included, vs. 107 MB for the Iron Bank base alone

grype, 2026-11-02. Iron Bank side: the public base image each recipe names (a floor; the real images add the application). Chainguard side: the full image from the org, standard variant.

95% of the replacement images have no Critical CVE



68 have no known CVE at all

15 have only Medium or Low CVEs

22 have a High CVE but no Critical

6 have a Critical CVE

6 distinct Critical CVEs across all 111, all in third-party code inside the app: GitLab EE's Rails images, Gitaly and Grafana's image renderer.

grype, 2026-11-02: the 111 Chainguard images (standard) that replace Big Bang 4.0.0's Iron Bank images.

Chainguard patches on a published clock

0 CVEs

Zero known CVEs at publish

The goal for every image when it ships; dependencies are rebuilt daily.

1 day

Fix SLA for KEV-listed CVEs

Critical in 7 days; High, Medium and Low in 14, from when a fix is public.

3,000+

Images, built from source

Plus 30,000+ packages, so each image carries only what the app needs.

SLSA L3

Verifiable provenance

Assessed by Coalfire. Signed SBOM and provenance with every image.

FIPS 140-3

Validated crypto modules

Kernel-independent, so FIPS images run on any recent Linux kernel.

STIG

Hardened to a DISA-based profile

Based on DISA's General Purpose OS SRG; scannable with OpenSCAP.

Chainguard's published claims (chainguard.dev, accessed Nov 2026): Containers product page; CVE Policy (Apr 28, 2026); SLSA Build Level 3 (Aug 17, 2026); FIPS Commitment (Sep 17, 2026); STIG docs. Full links on the last slide.

Federal teams report faster ATOs on Chainguard

Ask Sage

FedRAMP High + IL5 in 7 months

Zero vulnerabilities vs. 1,400 in alternatives; 30–40% less compliance work.

Collaboration.Ai

ATO in 90 days, not 2 years

97% fewer vulnerabilities and $2M saved, with Second Front and AWS.

Booz Allen Hamilton

Stalled ATO approved in 8 weeks

Now an enterprise license covering 6,000+ engineers (Jul 2026).

Shift5

Thousands of CVEs down to zero

FIPS and STIG images for its DoD customers; months of work saved.

233%

3-year ROI, payback under 6 months (Forrester TEI, commissioned by Chainguard)

Leader

2026 Gartner Magic Quadrant for Software Supply Chain Security

Platform One accepted Chainguard's Wolfi OS in 2023

Outcomes as published by Chainguard: chainguard.dev/customers and the Unchained blog (Forrester TEI, Feb 18, 2026; Gartner MQ, Jun 18, 2026; Platform One, Apr 18, 2023). Not independently verified.

This project does the Big Bang conversion for you

Doing it by hand means

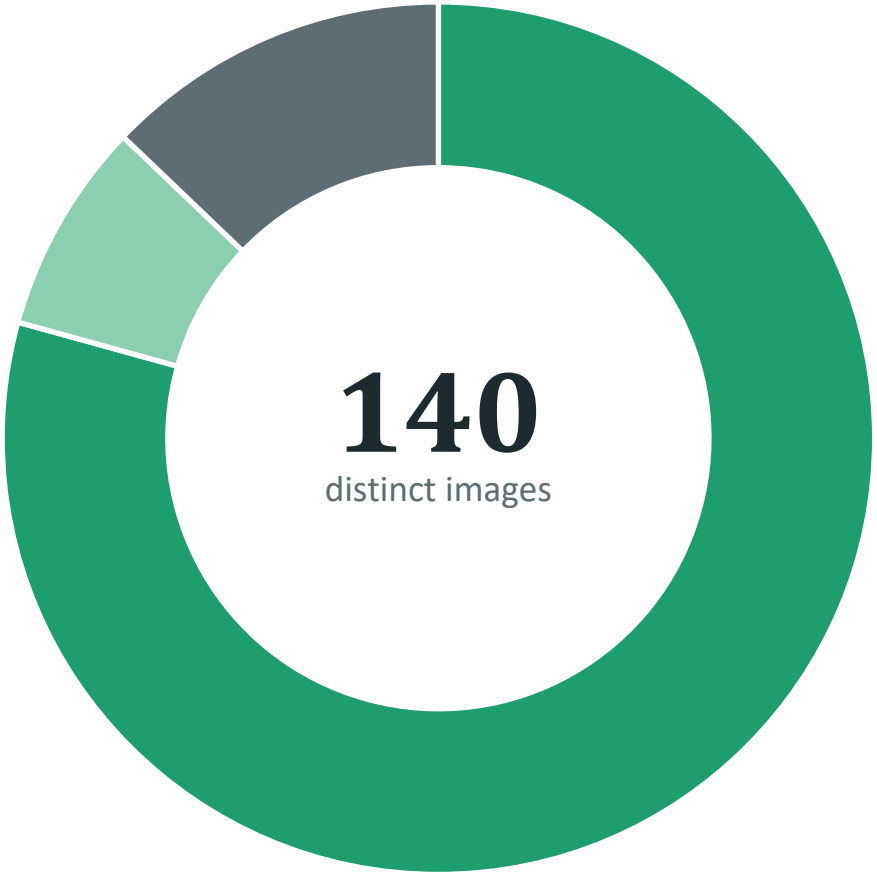
- 200+ image references across 44 packages, each chart setting images its own way
- Matching versions, and a FIPS twin, for every one
- Digests that change as Chainguard patches
- In practice: a fork of Big Bang to maintain

What you get instead: plain values overlays for the unmodified upstream Big Bang chart, regenerated and retested every night.

1. **Discover**
   Render Big Bang and every package; find every image it deploys
2. **Map and pin**
   Point each one at your org's image: exact tag, pinned by digest
3. **Test**
   Render every package, then run them on Kubernetes, standard and FIPS
4. **Release**
   A signed release; clusters move to it with one command

Every night. A new Big Bang release gets the same pipeline, and a person merges it.

Every package covered, standard and FIPS



111 come straight from your Chainguard org

11 are built here FROM Chainguard images, signed, with an SBOM

18 stay on Iron Bank: vendor products and UBI-based parts. None is in the default packages

44	~55	105
packages	images for the default packages	FIPS twins

docs/images.md and docs/required-images.md for Big Bang 4.0.0. Default packages: Istio, Kiali, Kyverno, cert-manager, Alloy, Loki, Tempo, monitoring, Grafana, NeuVector, metrics-server and Flux.

FIPS is one switch, not a project

177 of 183

image references have a FIPS twin; the other 6 are listed with the reason

```
bb-install.py install --fips
```

FIPS images come with Chainguard's Enterprise plan.

2×

Every Kubernetes test, twice

Each test runs in standard and FIPS mode (exceptions listed)

RHEL

On a FIPS-mode kernel

Kyverno, Grafana and Keycloak pass on a RHEL 9 node in FIPS mode

140-3

Validated modules, any kernel

Chainguard's FIPS images carry their own validated entropy source, so they don't depend on a FIPS host kernel

Project: README and docs/testing.md (FIPS-kernel run of 2026-11-02). Kernel independence: Chainguard docs, "Kernel-independent FIPS architecture" (updated 2026-09-28).

Tested on Kubernetes, not just rendered

38

Kubernetes tests, each proving the app works

596

unit tests on every change

40

problems found at runtime and fixed before anyone hit them

19 / 19

default releases healthy on CIS-hardened RKE2

Found and fixed, for example

- ✓ An Istio sidecar still pulled from Iron Bank
- ✓ Gatekeeper refused every image not from Iron Bank
- ✓ RKE2's restricted Pod Security refused Flux and Istio's gateways
- ✓ NeuVector's enforcer crashed at the common inotify limit; the installer now checks it

docs/testing.md ("What the runtime tests found"); RKE2 CIS-profile runs of 2026-11-05.

A supply chain you can verify end to end

- ✓ **Pinned by digest** A cluster runs exactly what CI tested
- ✓ **Signatures checked** Every Chainguard image, on every pull request
- ✓ **Enforced in the cluster** A Kyverno policy refuses unsigned images
- ✓ **Signed before release** Images built here are signed before their tag moves, with an SBOM and SLSA provenance
- ✓ **Gated** A fixable Critical CVE fails CI, nightly updates included
- ✓ **Kept fresh** CI fails on any image Chainguard hasn't rebuilt in 30 days
- ✓ **Locked-down CI** Builds, releases and updates reach only listed hosts; CodeQL and OpenSSF Scorecard run on every merge

IN PRACTICE, NOVEMBER 2026

Nov 6: a new Critical CVE, listed as known-exploited, appeared in a library inside Vault.

The nightly scan stopped the new image before it was published and held the update for a person.

Nov 11: Chainguard's rebuild cleared the scan, and the fixed Vault was published. No one had to notice it first.

README ("A supply chain you can verify"); builds.yml CVE gate; nightly updates, 2026-11-06 to 2026-11-11; harden-runner, CodeQL and Scorecard workflows.

Deploy in three commands

```
$ chainctl auth login
```

once: makes your pull token

```
$ bb-install.py check
```

tests every setting first

```
$ bb-install.py install --fips
```

does it all, then waits

Then: status, upgrade (shows the changes and asks first; converts Big Bang 3 sites) and rollback.

Get it: github.com/Zapata-Technology/bigbang-chainguard

check proves it before anything changes

- Cluster: Kubernetes 1.35+, storage, node limits
- Site file: Big Bang renders with it, so a bad key is caught
- Logins: every image is test-pulled, which proves your plan covers it
- Upgrade path from what the cluster runs now

install then sets up pull secrets, Flux, object storage, Big Bang, TLS and the signature policy, and waits until every package is healthy.

README ("Install") and docs/install.md.

The questions we hear first

? Why not stay on Iron Bank?

It's free, but the images keep their base layers' CVEs, and Chainguard notes it has no contractual fix SLA. Every finding stays your team's work.

? Why not Chainguard's free images?

Free images carry only latest tags; the free plan covers 5 images, with no fix SLA and no FIPS. Big Bang needs exact versions of 55+.

? Why not convert it ourselves?

200+ image references in 44 packages, each set differently, patched nightly. This project does it and tests it, and it's open source.

? Are we locked in to this project?

No. Big Bang isn't forked: the output is plain values overlays you can read, keep and regenerate for your own org.

Chainguard: alternatives page (Jul 16, 2026), container categories docs, pricing page. Project: README.

What you need to buy

A Chainguard Enterprise plan

~55 images cover Big Bang's default packages; 111 cover all 44 (plus 105 FIPS twins)

FIPS and contractual SLAs come with Enterprise; the free and Team plans have no FIPS catalog

$19K is where Chainguard says catalog pricing starts, for a team of 10; per-image plans also exist

THIS PROJECT

$0

- Open source (Apache-2.0), public on GitHub
- Regenerated for your own org with one command
- Its check proves your plan covers every image before you install

Chainguard pricing page and alternatives page (Jul 16, 2026), accessed Nov 2026. Image counts: docs/required-images.md (Big Bang 4.0.0).

Where it stands today

✓ Proven

- Unmodified Big Bang 4.0.0; all 44 packages mapped
- 38 Kubernetes tests, standard and FIPS
- Default packages healthy on CIS-hardened RKE2
- Upgrades from Big Bang 3.35.1 and release to release
- 21 signed releases on Big Bang 4.0.0

→ Not yet

- Beta: for development, test and evaluation clusters
- Not yet run on a production-sized, multi-node cluster
- 18 images stay on Iron Bank (none in the defaults)
- Keycloak's images pinned by tag, not digest (a Big Bang template limit)

A pilot on your hardware closes the first two gaps.

README ("Known gaps", status) and docs/for-big-bang.md.

Next step: a 60-day pilot

1

Weeks 0–2

Size and quote

Chainguard Enterprise with FIPS, from the image list for your packages

2

Weeks 2–5

Install on a dev cluster

check, then install, on your RKE2 with your site settings

3

Weeks 5–7

Measure

Scan with your own tools against today's Iron Bank deployment; keep it as ATO evidence

4

Week 8

Decide

Production plan, support model, and which packages move first

Zapata Technology runs the pilot with you, and maintains the project.

Start here: github.com/Zapata-Technology/bigbang-chainguard

Sources

Chainguard (chainguard.dev, accessed Nov 2026)

Containers product page: /products/containers (zero-CVE definition, catalog, daily rebuilds)

CVE Policy: /legal/cve-policy (Apr 28, 2026); one-day KEV SLA: /unchained/going-beyond-cves-chainguards-one-day-kev-sla

FIPS Commitment: /legal/fips-commitment (Sep 17, 2026); kernel independence: /docs/platform/fips/kernel-independent-architecture

STIG: /docs/chainguard/containers/security-and-compliance/stigs; /legal/disa-stig-commitment (Aug 14, 2026)

SLSA Build Level 3: /unchained/proven-not-promised-chainguard-containers-achieves-slsa-build-level-3 (Aug 17, 2026)

Pricing: /pricing; catalog pricing: /supply-chain-security-101/chainguard-alternatives (Jul 16, 2026)

Free images: /docs/chainguard/containers/concepts/container-categories

Customers and research (Chainguard-published)

Ask Sage, Shift5: /customers; Collaboration.Ai: /unchained (Jul 23, 2025)

Booz Allen: /unchained (Oct 15, 2025; ELA Jul 21, 2026)

Forrester TEI, commissioned by Chainguard: /unchained (Feb 18, 2026)

Gartner MQ: /unchained (Jun 18, 2026). Gartner does not endorse vendors in its research

Platform One: /unchained (Apr 18, 2023)

This project (bigbang-chainguard)

github.com/Zapata-Technology/bigbang-chainguard (Apache-2.0)

CVEs and sizes: grype, 2026-11-02 (README; weekly cve-report.yml)

Tests and findings: docs/testing.md; RKE2 CIS runs, 2026-11-05

Image counts: docs/images.md, docs/required-images.md (Big Bang 4.0.0)